

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

Consider the following questions to help you write:

- *How is the database server valuable to the business?*
- *Why is it important for the business to secure the data on the server?*
- *How might the server impact the business if it were disabled?*

The database server is the core component of websites where all data is stored. It is extremely valuable to maintain its security to ensure confidentiality, availability, and integrity.

Failing to secure the data on the server would incur penalties in case of a breach including fines and loss of reputation and customer trust.

If the server is disabled, the website can no longer function, losing the availability and causing losses with each second it is offline.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Competitor	Obtain sensitive information via exfiltration	3	3	9

Hacker	DDOS or unauthorized access through the network used to access other servers.	2	2	4
Employee	Insider threat, could cause harm to take revenge.	2	3	6

Approach

This section documents the approach used to conduct the vulnerability assessment report. It is important to be clear and concise when writing your approach. A transparent summary of your approach helps stakeholders understand that the assessment is credible and that the results can be used to make informed decisions.

Consider the following questions to help you write an approach section:

- *What was your rationale for selecting the risks that you evaluated?*
- *How were you deriving the likelihood and severity scores of each risk?*
- *What were the limitations of the assessment?*

For businesses, a competitor is the biggest risk. Attempts to steal trade secrets to gain an edge in the industry are extremely common, and the severity is extreme for financial reasons. As for hackers, hackers stand to benefit financially from targeting businesses either by using ransomware after exploiting a system or by selling found exploits or backdoors on the dark web. As for insider threats, such as employees, a disgruntled employee is one of the most dangerous risks due to the level of knowledge, privilege, and access they possess.

The likelihood scores were derived based on the business nature, as for the severity, it was derived using the NIST-SP800-30 Rev1 document.

The assessment was limited due to a lack of information. There is not enough information about the business nature and what services were present as front-facing services or what protections were already set in place.

Remediation Strategy

This section provides specific and actionable recommendations to remediate or mitigate the risks that were assessed. Any recommendations that you make should be realistic and achievable. Overall, the remediation section of a vulnerability assessment report helps to ensure that risks are addressed in a timely and effective manner.

Consider the following questions to help you write a remediation strategy:

- Which technical, operational, or managerial controls are currently implemented to secure the system?
- Are there security controls that can reduce the risks you evaluated? What are those controls and how would they remediate the risks?
- How will the results of the assessment improve the overall security of the system?

Current controls in place are the following:

- *SSL/TLS encrypted connection securing communication from network sniffing.*

Security Controls to remediate mentioned risks:

- *Conduct regular access control audits and pen tests. This ensures finding vulnerable attack vectors before the hackers or competitors.*
- *Apply a separation of duties policy to limit the employee's capacity to cause harm.*
- *Implement Multi-factor authentication.*
- *Apply the principle of least privilege.*
- *Disable legacy SSL encryption as it is deprecated. Enforce the use of TLS.*

Following this assessment would mitigate risks and reduce the severity of impacts.

Increasing internal checks hardens the systems against external attacks, ensuring any broken access controls are found before threat actors.

Setting up MFA protects against weak or stolen password attacks.

Separation of duties and PoLP add protection against internal threats.